

Product Requirements Document (PRD)

App Name: CloudGuard GRC[cite: 1]

One-Line Idea: Automate multi-cloud security audits and compliance checks: scan AWS/Azure/GCP accounts for misconfigurations, exposed secrets, and policy violations, and present unified GRC reports[cite: 1].

1. Executive Summary

CloudGuard GRC is a cloud security auditing and GRC tool that continuously scans cloud infrastructure (AWS, and eventually Azure/GCP) to detect misconfigurations, exposed secrets, and policy violations[cite: 1]. It brings Governance, Risk, and Compliance (GRC) automation to cloud environments by leveraging provider APIs in a read-only, agentless manner[cite: 1]. Acting as a Cloud Security Posture Management (CSPM) solution, CloudGuard GRC provides automated visibility and audit evidence[cite: 1]. The MVP enables users to onboard cloud accounts, run automated scans (e.g., CIS benchmark checks), and view prioritized findings with remediation guidance in a unified dashboard[cite: 1].

2. Target Users & Personas

- **Security/Cloud Engineers (SMB to Enterprise):** Need continuous monitoring of cloud accounts and enforcement of security policies across multi-account setups[cite: 1].
- **DevOps Engineers / Cloud Architects:** Manage Infrastructure as Code (IaC) and require integration of security checks into CI/CD pipelines[cite: 1].
- **IT Auditors / Compliance Officers:** Need audit-ready reports showing adherence to standards (CIS, NIST, ISO, GDPR)[cite: 1].
- **Management / Executives:** Gain confidence from aggregated compliance dashboards and reduced risk exposure[cite: 1].
- **Personas:**
 - Alice, Security Architect at a mid-size enterprise[cite: 1].
 - Bob, DevOps Engineer at a startup[cite: 1].
 - Charlie, Compliance Officer in healthcare[cite: 1].

3. Problem Statement & Value Proposition

Problem: Cloud infrastructure is highly dynamic, leading to frequent security gaps and breaches due to preventable misconfigurations[cite: 1]. Manually auditing AWS/Azure/GCP resources (IAM

roles, storage policies, logs) is labor-intensive and error-prone[cite: 1]. Organizations lack automated visibility to continuously gather compliance evidence[cite: 1].

Value Proposition:

- **Automated Visibility:** Provides a single pane of glass for multi-account cloud security posture[cite: 1].
- **Compliance Readiness:** Continuously runs policy checks mapped to CIS, NIST, ISO 27001, and GDPR controls[cite: 1].
- **Risk Prioritization:** Scores findings by severity using a weighted ThreatScore to highlight critical issues[cite: 1].
- **Actionable Remediation:** Offers concrete fix instructions (console links, CLI commands, IaC snippets) and optional automated fixes[cite: 1].
- **Multi-Cloud & Scalability:** Agentless API architecture designed to scale across multi-account AWS, Azure, and GCP environments[cite: 1].

4. Core Features

1. **Account Onboarding & Inventory:** Securely connect cloud accounts via read-only credentials (IAM role for AWS, Service Principal for Azure) to inventory resources[cite: 1].
2. **Resource & Activity Scan Engine:** Periodic or on-demand scanning using cloud APIs (boto3 for AWS, Cloud Asset API for GCP) with event-driven change detection[cite: 1].
3. **Misconfiguration Checks:** Built-in rules for CIS benchmarks, root MFA, S3 public access, KMS rotation, and security group restrictions[cite: 1].
4. **Secret/Key Exposure Detection:** Scans IAM access keys, S3 objects, and repositories for hardcoded plaintext secrets or stale credentials[cite: 1].
5. **Findings Dashboard & Prioritization:** Centralized UI sortable by severity, account, service, or compliance framework with weighted scoring[cite: 1].
6. **Remediation Guidance:** Step-by-step resolution steps (CLI commands, Terraform snippets) and optional auto-remediation via Lambda[cite: 1].
7. **Compliance Reporting:** Automated compliance matrices and downloadable PDF/CSV audit reports[cite: 1].
8. **Alerts & Integrations:** Real-time notifications via Email, Slack, webhooks, SIEM (Splunk, QRadar), and ITSM tools (Jira, ServiceNow)[cite: 1].
9. **CI/CD / IaC Hooks:** CLI and API integration to scan Terraform and CloudFormation templates in deployment pipelines[cite: 1].
10. **User Management & RBAC:** Granular role-based access controls enforcing least privilege internally[cite: 1].
11. **Multi-Account & Multi-Cloud:** Multi-account management via AWS Organizations / Azure Management Groups[cite: 1].
12. **Audit Trail & Logging:** Comprehensive logging of all tool actions and historical scan results stored for at least one year[cite: 1].
13. **REST API:** Programmable REST endpoints to orchestrate scans, export results, and manage accounts[cite: 1].

5. User Roles & Permissions

- **Super Admin:** Full administrative access, user management, cloud account configuration, and global policy definitions[cite: 1].
- **Cloud Account Admin:** Account connection, scan schedule management, and finding views for assigned accounts[cite: 1].
- **Security Analyst:** Runs scans, triages findings, exports reports, and initiates remediations[cite: 1].
- **Auditor (Read-Only):** View-only access to dashboards, compliance status, and audit evidence reports[cite: 1].
- **Viewer:** Basic read-only access to summarized dashboards for specific accounts[cite: 1].

6. User Stories

1. **Account Onboarding:** As a Security Engineer, I want to add my AWS account by providing an IAM role ARN, so that the tool can securely scan that account's resources[cite: 1].
2. **Continuous Scan:** As an Admin, I want daily automatic scans of all connected accounts, so I always have up-to-date audit data without manual effort[cite: 1].
3. **View Findings:** As a Compliance Officer, I want to see a consolidated list of all security findings across my cloud accounts, sorted by severity, so I can identify critical issues first[cite: 1].
4. **Remediation Steps:** As a Developer, I want to click on a finding (e.g., "Public S3 Bucket") and see step-by-step instructions to fix it, so I can quickly remediate[cite: 1].
5. **Compliance Report:** As an Auditor, I want to generate a PDF report showing compliance status against CIS and ISO controls, so I can include it in audit evidence[cite: 1].
6. **RBAC Enforcement:** As an Organization Owner, I want to assign an "Auditor" role to a colleague so they can view reports without modifying configs[cite: 1].
7. **CI/CD Integration:** As a DevOps Engineer, I want to invoke the scanner on Terraform templates in CI pipelines to catch misconfigs before deployment[cite: 1].
8. **Alerts:** As an Operations Manager, I want to receive Slack notifications when a new critical vulnerability is found for immediate response[cite: 1].
9. **Multi-Cloud:** As a CTO, I want to add both AWS and Azure environments to see all cloud risks in one dashboard[cite: 1].
10. **Trend Analysis:** As a Security Manager, I want to view charts of issue counts over time to measure security posture improvements[cite: 1].
11. **Secret Scanning:** As a Security Engineer, I want the system to detect exposed AWS keys in S3 or Git repos to rotate them before misuse[cite: 1].
12. **Automated Fix:** As an Admin, I want to click "Auto-Remediate" to trigger a Lambda that automatically resolves common issues[cite: 1].

7. Success Metrics (KPIs)

- **Coverage:** Percentage of cloud accounts and resources actively monitored (targeting 100% of AWS accounts)[cite: 1].
- **Detection Rate & Time:** Rapid identification of misconfigurations in <24 hours[cite: 1].
- **Time to Remediation:** Target 30% reduction in average fix time compared to manual auditing[cite: 1].

- **Compliance Score:** Raising average CIS benchmark score (e.g., improving from 80% to 90%)[cite: 1].
- **Platform Reliability:** High uptime, quick scan execution, and low false-positive rates[cite: 1].

8. MVP Scope & Feature Matrix

Capability	In v1 (MVP)	Future v2+
AWS Account Scanning	✓[cite: 1]	✓[cite: 1]
Azure / GCP Scanning	Excluded[cite: 1]	✓[cite: 1]
Read-Only API Approach	✓[cite: 1]	✓[cite: 1]
CIS AWS Foundations Checks	✓[cite: 1]	Extended Standards[cite: 1]
Secret & Key Exposure Scanning	✓ (Basic IAM/S3)[cite: 1]	Extended[cite: 1]
Automated Remediation	Guidance Only[cite: 1]	One-Click Auto-Fix[cite: 1]
RBAC Support	Basic (Admin / Auditor)[cite: 1]	Advanced Hierarchy[cite: 1]
Reports & Exports	PDF / CSV Exports[cite: 1]	Enhanced BI / Custom Reports[cite: 1]

9. Features Excluded from Version 1

- Agent-based scanning (100% agentless API approach)[cite: 1].
- Multi-cloud support (Azure/GCP deferred to v2)[cite: 1].
- Automated one-click remediation execution[cite: 1].
- Machine learning / attack path graph analytics[cite: 1].
- Custom user-defined policy rule builders[cite: 1].
- Enterprise SSO integration (standard Cognito/auth used in MVP)[cite: 1].
- Mobile applications or hardware/IoT device scanning[cite: 1].

10. Architecture Overview

- **Frontend:** React/Vue single-page web application[cite: 1].
- **Backend API:** Python/Node.js REST API service deployed on AWS (ECS/EKS or Lambda) [cite: 1].
- **Database:** AWS RDS PostgreSQL or DynamoDB storing scan results and metadata[cite: 1].
- **Scan Workers:** AWS Lambda / Docker tasks executing boto3 API calls under assumed read-only roles[cite: 1].
- **Queue/Workflow:** AWS SQS and Step Functions orchestrating parallel scan tasks per account/region[cite: 1].

- **Security:** KMS encryption at rest, HTTPS in transit, AWS Cognito for auth, and least-privilege IAM policies[cite: 1].

11. Implementation Roadmap (6-Month Timeline)

Phase	Duration	Milestones / Deliverables
1. Planning & Setup	Month 0-1	Finalize architecture, set up repositories/CI, create IAM dev roles[cite: 1].
2. Core AWS Engine	Month 1-3	Implement boto3 AWS integration, CIS rules, and core UI dashboard[cite: 1].
3. Feature Expansion	Month 3-5	Add EC2/KMS/Logging checks, RBAC, multi-account support, and alerting[cite: 1].
4. Testing & Release	Month 5-6	Integration testing, performance tuning, user guide, and v1.0 release[cite: 1].

12. Risks & Mitigations

- **API Rate Limits:** Mitigated using back-off retry logic, pagination, and caching via AWS Config[cite: 1].
- **Data Sensitivity:** Mitigated via KMS encryption, strict internal RBAC, and minimal read-only IAM policies[cite: 1].
- **False Positives:** Mitigated by allowing manual findings suppression and continuous rule refinement[cite: 1].